

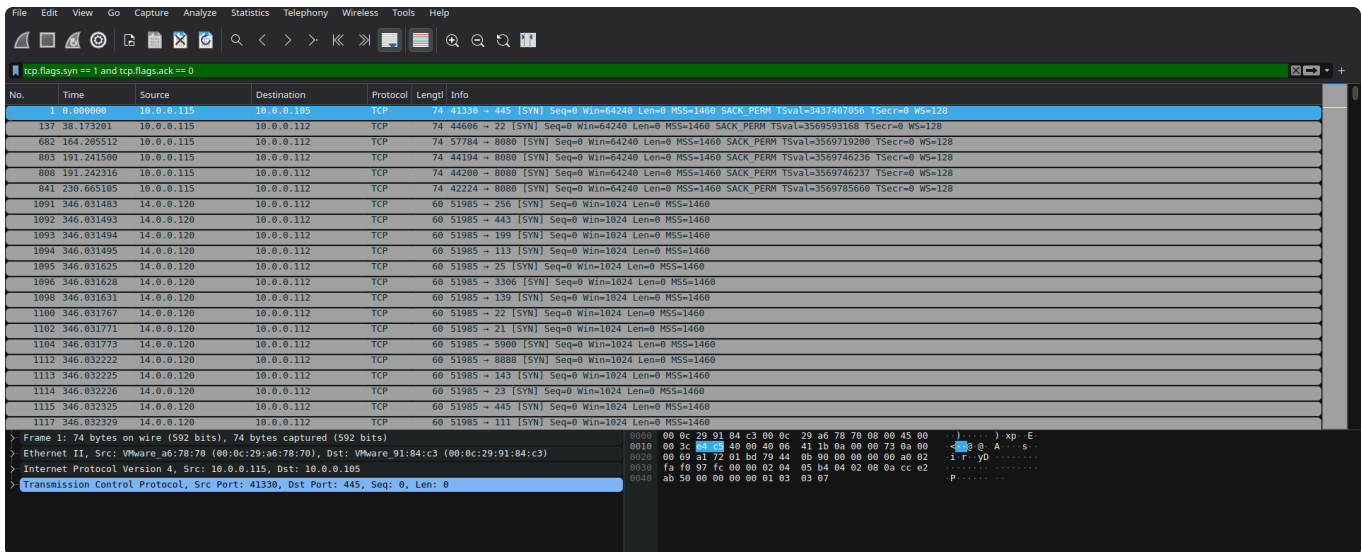
Scenario

The SOC team has identified suspicious activity on a web server within the company's intranet. To better understand the situation, they have captured network traffic for analysis. The PCAP file may contain evidence of malicious activities that led to the compromise of the Apache Tomcat web server. Your task is to analyze the PCAP file to understand the scope of the attack.

Given the suspicious activity detected on the web server, the PCAP file reveals a series of requests across various ports, indicating potential scanning behavior. Can you identify the source IP address responsible for initiating these requests on our server?

As mentioned in the question that scanning occurred, we can filter the traffic of only SYN packets without any ACK response. If there are too many requests like this sourcing from same IP, then that IP is likely the attacker.

```
tcp.flags.syn == 1 and tcp.flags.ack == 0
```



After filtering the SYN traffic, we can look at IPv4 conversations to identify the attacker's IP which will be the one with most packets transferred.

Wireshark - Conversations - web server.pcap

Conversation Settings

☐ Name resolution

☐ Absolute start time

☒ Limit to display filter

Copy

Follow Stream...

Graph...

Protocol

☐ Bluetooth

☐ BPv7

☐ DCCP

☒ Ethernet

☐ FC

☐ FDDI

☐ IEEE 802.11

☐ IEEE 802.15.4

☒ IPv4

☒ IPv6

☐ IPX

Filter list for specific type

Help

X Close

Ethernet - 3

IPv4 - 3

IPv6

TCP - 9456

UDP

Address A	Address B	Packets	Bytes	Total Packets	Percent Filtered	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A
14.0.0.120	10.0.0.112	9,449	567 kB	19,607	48.19%	9,447	567 kB	2	148 bytes	346.031483	395.1127	11 kbps	2 bits/s
10.0.0.115	10.0.0.112	6	444 bytes	1,323	0.45%	6	444 bytes	0	0 bytes	38.173201	832.4581	4 bits/s	0 bits/s
10.0.0.115	10.0.0.105	1	74 bytes	136	0.74%	1	74 bytes	0	0 bytes	0.000000	25.4627	23 bits/s	0 bits/s

Answer: 14.0.0.120

Based on the identified IP address associated with the attacker, can you identify the country from which the attacker's activities originated?

To identify the country of attacker, we can use iplocation.com.



IP LOCATION

INSTANTLY LOCATE ANY IP ADDRESS

This free online tool allows you to see the geographical location of any IP address. Just input the IP address and you will be shown the position on a map, coordinates, country, region, city and organization.

IP address	14.0.0.120 (change)
Latitude	23.127361
Longitude	113.264572
Country	China
Region	Guangdong
City	Guangzhou
Organization	ChinaNet Guangdong Province Network



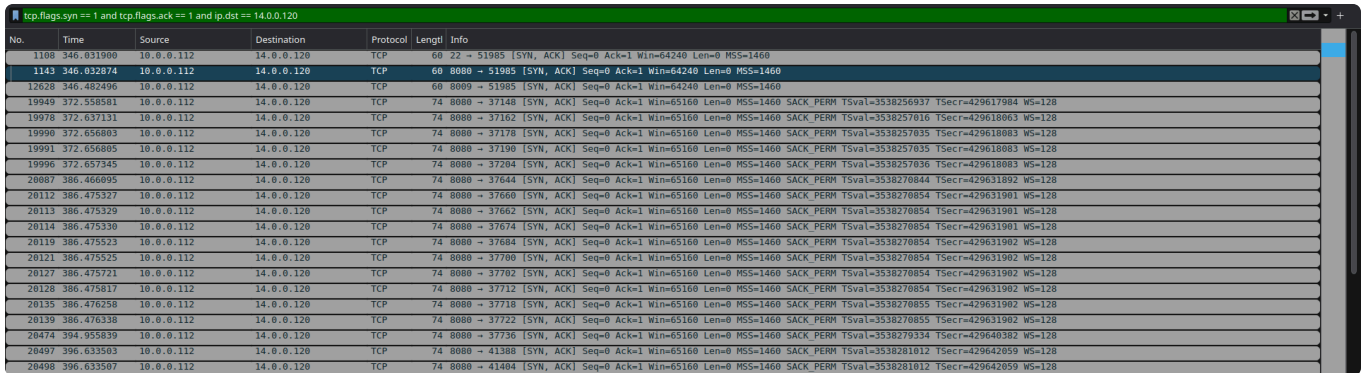
IP geolocation by IP2Location.

Answer: china

From the PCAP file, multiple open ports were detected as a result of the attacker's active scan. Which of these ports provides access to the web server admin panel?

To identify the ports which provided access to admin panel, we can filter for the traffic which gets ACK response for SYN sourcing from the attacker's IP.

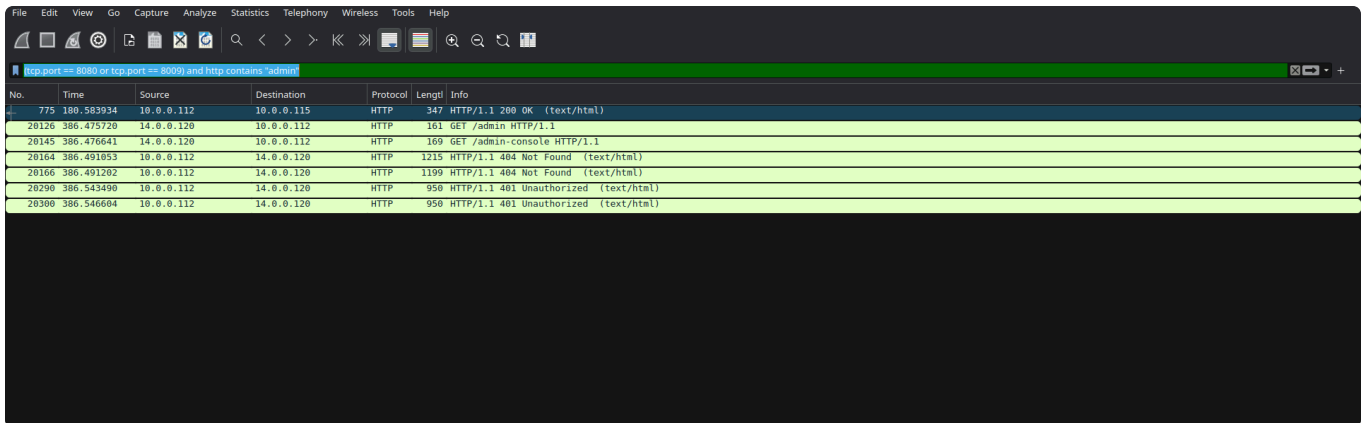
```
tcp.flags.syn == 1 and tcp.flags.ack == 1 and ip.dst == 14.0.0.120
```



No.	Time	Source	Destination	Protocol	Length	Info
1108	345.631960	10.0.0.112	14.0.0.120	TCP	60	22 → 51985 [SYN, ACK] Seq=0 Ack=1 Wln=64240 Len=0 MSS=1460
1143	345.632074	10.0.0.112	14.0.0.120	TCP	60	8080 → 51985 [SYN, ACK] Seq=0 Ack=1 Wln=64240 Len=0 MSS=1460
12628	346.482496	10.0.0.112	14.0.0.120	TCP	60	8009 → 51985 [SYN, ACK] Seq=0 Ack=1 Wln=64240 Len=0 MSS=1460
19949	372.558581	10.0.0.112	14.0.0.120	TCP	74	8080 → 37148 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538256937 TSecr=429617984 WS=128
19978	372.637131	10.0.0.112	14.0.0.120	TCP	74	8080 → 37152 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538257016 TSecr=429618063 WS=128
19998	372.656803	10.0.0.112	14.0.0.120	TCP	74	8080 → 37178 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538257035 TSecr=429618083 WS=128
19991	372.656805	10.0.0.112	14.0.0.120	TCP	74	8080 → 37190 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538257035 TSecr=429618083 WS=128
19996	372.657345	10.0.0.112	14.0.0.120	TCP	74	8080 → 37204 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538257036 TSecr=429618083 WS=128
20007	386.466695	10.0.0.112	14.0.0.120	TCP	74	8080 → 37644 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538270844 TSecr=429631892 WS=128
20112	386.475327	10.0.0.112	14.0.0.120	TCP	74	8080 → 37660 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538270854 TSecr=429631901 WS=128
20113	386.475329	10.0.0.112	14.0.0.120	TCP	74	8080 → 37662 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538270854 TSecr=429631901 WS=128
20114	386.475330	10.0.0.112	14.0.0.120	TCP	74	8080 → 37674 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538270854 TSecr=429631901 WS=128
20119	386.475523	10.0.0.112	14.0.0.120	TCP	74	8080 → 37684 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538270854 TSecr=429631902 WS=128
20121	386.475525	10.0.0.112	14.0.0.120	TCP	74	8080 → 37700 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538270854 TSecr=429631902 WS=128
20127	386.475721	10.0.0.112	14.0.0.120	TCP	74	8080 → 37702 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538270854 TSecr=429631902 WS=128
20128	386.475817	10.0.0.112	14.0.0.120	TCP	74	8080 → 37712 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538270854 TSecr=429631902 WS=128
20135	386.476258	10.0.0.112	14.0.0.120	TCP	74	8080 → 37718 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538270855 TSecr=429631902 WS=128
20139	386.476338	10.0.0.112	14.0.0.120	TCP	74	8080 → 37722 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538270855 TSecr=429631902 WS=128
20474	394.955839	10.0.0.112	14.0.0.120	TCP	74	8080 → 37736 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538279334 TSecr=429640382 WS=128
20497	396.633503	10.0.0.112	14.0.0.120	TCP	74	8080 → 41388 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538281012 TSecr=429642059 WS=128
20498	396.633507	10.0.0.112	14.0.0.120	TCP	74	8080 → 41484 [SYN, ACK] Seq=0 Ack=1 Win=65168 Len=0 MSS=1460 SACK_PERM TSval=3538281012 TSecr=429642059 WS=128

From the filtered traffic, we can notice that port 8080 and 8009 are sending ACK. So we can now filter for

```
(tcp.port == 8080 or tcp.port == 8009) and http contains "admin"
```



No.	Time	Source	Destination	Protocol	Length	Info
775	180.583934	10.0.0.112	10.0.0.115	HTTP	347	HTTP/1.1 200 OK (text/html)
20126	386.475720	14.0.0.120	10.0.0.112	HTTP	161	GET /admin HTTP/1.1
20145	386.476641	14.0.0.120	10.0.0.112	HTTP	169	GET /admin-console HTTP/1.1
20164	386.491853	10.0.0.112	14.0.0.120	HTTP	1215	HTTP/1.1 404 Not Found (text/html)
20166	386.491282	10.0.0.112	14.0.0.120	HTTP	1199	HTTP/1.1 404 Not Found (text/html)
20290	386.543490	10.0.0.112	14.0.0.120	HTTP	950	HTTP/1.1 401 Unauthorized (text/html)
20380	386.546604	10.0.0.112	14.0.0.120	HTTP	950	HTTP/1.1 401 Unauthorized (text/html)

After viewing the details of packet with GET request for admin-console, we can identify the port number.

tcp.port == 8080 or tcp.port == 8009 and http contains 'admin'

No.	Time	Source	Destination	Protocol	Length	Info
775	180.583934	10.0.0.112	10.0.0.115	HTTP	347	HTTP/1.1 200 OK (text/html)
20126	386.475720	14.0.0.120	10.0.0.112	HTTP	161	GET /admin HTTP/1.1
20145	386.476641	14.0.0.120	10.0.0.112	HTTP	169	GET /admin-console HTTP/1.1
20164	386.491053	10.0.0.112	14.0.0.120	HTTP	1215	HTTP/1.1 404 Not Found (text/html)
20166	386.491202	10.0.0.112	14.0.0.120	HTTP	1199	HTTP/1.1 404 Not Found (text/html)
20290	386.543490	10.0.0.112	14.0.0.120	HTTP	950	HTTP/1.1 401 Unauthorized (text/html)
20300	386.546604	10.0.0.112	14.0.0.120	HTTP	950	HTTP/1.1 401 Unauthorized (text/html)

> Frame 20145: 169 bytes on wire (1352 bits), 169 bytes captured (1352 bits)

> Ethernet II, Src: VMware_4b:ae:ba (00:0c:29:4b:ae:ba), Dst: VMware_4d:6a:d0 (00:0c:29:4d:6a:d0)

> Internet Protocol Version 4, Src: 14.0.0.120, Dst: 10.0.0.112

> Transmission Control Protocol, Src Port: 37702, Dst Port: 8080, Seq: 1, Ack: 1, Len: 103

Source Port: 37702

Destination Port: 8080

[Stream Index: 9452]

> [Conversation completeness: Complete, WITH DATA (31)]

[TCP Segment Len: 103]

Sequence Number: 1 (relative sequence number)

Sequence Number (raw): 972876038

[Next Sequence Number: 104 (relative sequence number)]

Acknowledgment Number: 1 (relative ack number)

Acknowledgment number (raw): 2258371399

1000 = Header Length: 32 bytes (8)

> Flags: 0x018 (PSH, ACK)

Window: 502

Answer: 8080

Following the discovery of open ports on our server, it appears that the attacker attempted to enumerate and uncover directories and files on our web server. Which tools can you identify from the analysis that assisted the attacker in this enumeration process?

To identify the tool, we can filter only GET requests sourcing from attacker's IP.

http.request.method == "GET" and ip.src == 14.0.0.120

tcp.port == 8080 or tcp.port == 8009 and http.request.method == "GET" and ip.src == 14.0.0.120

No.	Time	Source	Destination	Protocol	Length	Info
19951	372.558933	14.0.0.120	10.0.0.112	HTTP	405	GET / HTTP/1.1
19969	372.634510	14.0.0.120	10.0.0.112	HTTP	352	GET /tomcat.css HTTP/1.1
19976	372.636777	14.0.0.120	10.0.0.112	HTTP	359	GET /tomcat.png HTTP/1.1
19985	372.655751	14.0.0.120	10.0.0.112	HTTP	369	GET /bg-nav.png HTTP/1.1
19986	372.656038	14.0.0.120	10.0.0.112	HTTP	376	GET /asf-logo-wide.svg HTTP/1.1
19995	372.657242	14.0.0.120	10.0.0.112	HTTP	371	GET /bg-upper.png HTTP/1.1
19998	372.657348	14.0.0.120	10.0.0.112	HTTP	372	GET /bg-button.png HTTP/1.1
20002	372.657539	14.0.0.120	10.0.0.112	HTTP	372	GET /bg-middle.png HTTP/1.1
20052	372.675979	14.0.0.120	10.0.0.112	HTTP	368	GET /favicon.ico HTTP/1.1
20089	386.466599	14.0.0.120	10.0.0.112	HTTP	156	GET / HTTP/1.1
20106	386.472265	14.0.0.120	10.0.0.112	HTTP	192	GET /0a2cd016-3c71-4411-b1a1-0287040f02d1 HTTP/1.1
20108	386.474618	14.0.0.120	10.0.0.112	HTTP	185	GET /examples/servlet/SnoopServlet HTTP/1.1
20125	386.475719	14.0.0.120	10.0.0.112	HTTP	182	GET /examples/jsp/snp/snoop.jsp HTTP/1.1
20126	386.475720	14.0.0.120	10.0.0.112	HTTP	161	GET /admin HTTP/1.1
20138	386.476337	14.0.0.120	10.0.0.112	HTTP	164	GET /examples HTTP/1.1
20140	386.476414	14.0.0.120	10.0.0.112	HTTP	179	GET /examples/jsp/index.html HTTP/1.1
20144	386.476565	14.0.0.120	10.0.0.112	HTTP	187	GET /examples/servlet/TroubleShooter HTTP/1.1
20145	386.476641	14.0.0.120	10.0.0.112	HTTP	169	GET /admin-console HTTP/1.1
20148	386.476887	14.0.0.120	10.0.0.112	HTTP	179	GET /examples/jsp/source.jsp HTTP/1.1
20149	386.476892	14.0.0.120	10.0.0.112	HTTP	190	GET /examples/servlet/HelloWorldExample HTTP/1.1
20152	386.477089	14.0.0.120	10.0.0.112	HTTP	161	GET /docs/ HTTP/1.1

> Frame 20106: 192 bytes on wire (1536 bits), 192 bytes captured (1536 bits)

> Ethernet II, Src: VMware_4b:ae:ba (00:0c:29:4b:ae:ba), Dst: VMware_4d:6a:d0 (00:0c:29:4d:6a:d0)

> Internet Protocol Version 4, Src: 14.0.0.120, Dst: 10.0.0.112

> Transmission Control Protocol, Src Port: 37644, Dst Port: 8080, Seq: 91, Ack: 11373, Len: 126

> Hypertext Transfer Protocol

GET /0a2cd016-3c71-4411-b1a1-0287040f02d1 HTTP/1.1\r\n

Host: 10.0.0.112:8080\r\n

User-Agent: gobuster/3.6\r\n

Accept-Encoding: gzip\r\n

\r\n

[Full request URI: http://10.0.0.112:8080/0a2cd016-3c71-4411-b1a1-0287040f02d1]

[HTTP request 2/16]

[Prev request in frame: 20089]

[Response in frame: 20107]

[Next request in frame: 20109]

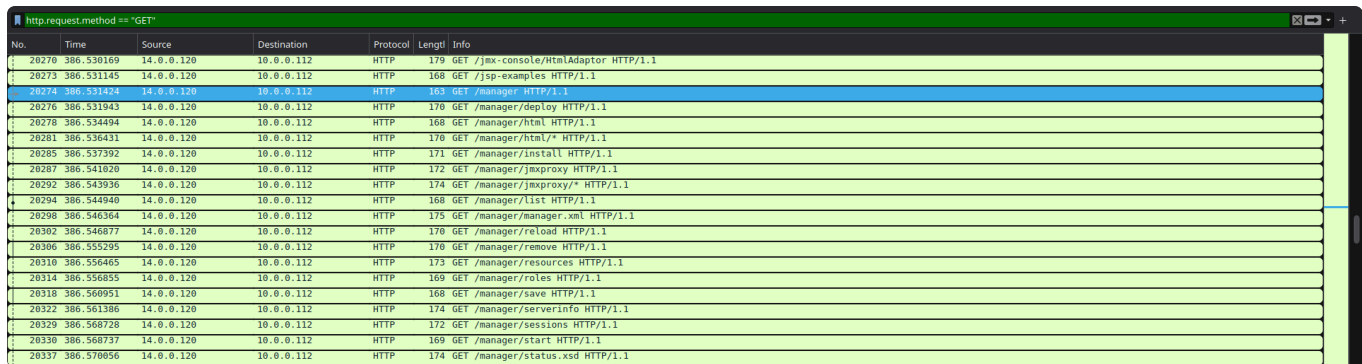
By viewing HTTP details of packets, we can see gobuster as user-agent, so it is our answer.

Answer: gobuster

After enumerating directories on our web server, the attacker made numerous requests to identify administrative interfaces. Which directory related to the admin panel did the attacker uncover? (Provide the path including the leading slash, e.g. /path)

For this, we can again filter GET requests only and by inspecting the requests, we'll notice the administrative interface.

```
http.request.method == "GET" and ip.src == 14.0.0.120
```



No.	Time	Source	Destination	Protocol	Length	Info
20270	386.530169	14.0.0.120	10.0.0.112	HTTP	179	GET /jmx-console/HtmlAdaptor HTTP/1.1
20273	386.531145	14.0.0.120	10.0.0.112	HTTP	168	GET /jsp-examples HTTP/1.1
20274	386.531424	14.0.0.120	10.0.0.112	HTTP	163	GET /manager HTTP/1.1
20276	386.531943	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/deploy HTTP/1.1
20278	386.534494	14.0.0.120	10.0.0.112	HTTP	168	GET /manager/html HTTP/1.1
20281	386.536431	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/html/* HTTP/1.1
20285	386.537392	14.0.0.120	10.0.0.112	HTTP	171	GET /manager/install HTTP/1.1
20287	386.541820	14.0.0.120	10.0.0.112	HTTP	172	GET /manager/jmxproxy HTTP/1.1
20292	386.543936	14.0.0.120	10.0.0.112	HTTP	174	GET /manager/jmxproxy/* HTTP/1.1
20294	386.544940	14.0.0.120	10.0.0.112	HTTP	168	GET /manager/list HTTP/1.1
20298	386.546364	14.0.0.120	10.0.0.112	HTTP	175	GET /manager/manager.xml HTTP/1.1
20302	386.546877	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/reload HTTP/1.1
20306	386.555295	14.0.0.120	10.0.0.112	HTTP	170	GET /manager/remove HTTP/1.1
20310	386.556465	14.0.0.120	10.0.0.112	HTTP	173	GET /manager/resources HTTP/1.1
20314	386.556855	14.0.0.120	10.0.0.112	HTTP	169	GET /manager/roles HTTP/1.1
20318	386.560951	14.0.0.120	10.0.0.112	HTTP	168	GET /manager/save HTTP/1.1
20322	386.561386	14.0.0.120	10.0.0.112	HTTP	174	GET /manager/serverinfo HTTP/1.1
20329	386.568728	14.0.0.120	10.0.0.112	HTTP	172	GET /manager/sessions HTTP/1.1
20330	386.568737	14.0.0.120	10.0.0.112	HTTP	169	GET /manager/start HTTP/1.1
20337	386.578856	14.0.0.120	10.0.0.112	HTTP	174	GET /manager/status.xsd HTTP/1.1

Answer: /manager

After accessing the admin panel, the attacker brute-forced the login. What credentials did the attacker successfully use? (Provide them in username:password format)

If attacker brute-forced with username and password, there will be POST requests which can provide us the answer.

```
http.request.method == "POST" and http contains "manager"
```

By viewing details of POST request, we can notice the username and password in Authorization field.

```
http.request.method == "POST" and http.contains("manager")
```

No.	Time	Source	Destination	Protocol	Length	Info
28616	547.381269	14.61.0.120	10.0.0.112	HTTP	712	POST /manager/html/upload;jsessionid=0DE586F2B2F48D0CA45F731E09E717org.apache.catalina.filters.CSRF_NONCE=83EDFAE2462ECC725DAF342D07A4697A HTTP/1.1

```
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8\r\n
Accept-Language: en-US,en;q=0.5\r\n
Accept-Encoding: gzip, deflate\r\n
Referer: http://10.0.0.112:8080/manager/html/\r\n
Content-Type: multipart/form-data; boundary=-----30985488594091180771288869606\r\n
Content-Length: 1324\r\n
Origin: http://10.0.0.112:8080\r\n
Authorization: Basic YmRtaWw4dG9tY2F0\r\n
    Credentials: admin:tomcat
Connection: keep-alive\r\n
Cookie: JSESSIONID=0DE586F2B2F48D0CA45F731E09E717\r\n
Upgrade-Insecure-Requests: 1\r\n
\r\n
```

```
0000 00 0c 29 4d 6a d9 00 0c 29 4b ae ba 08 00 45 00 ...J)M...K...E
0010 02 ba ab c1 4f 00 49 06 77 71 0e 00 00 78 0a 00 ...@...wq...x
0020 00 70 ac fe 1f 90 68 08 43 40 cc 42 cb 00 18 00 p...h CQ B...
0030 01 f6 b6 3a 00 09 01 01 06 0a 19 9a 18 28 c2 48 f...f...C...(-
0040 2f 0f cb 50 61 fa 6c 1b 41 05 f5 35 38 d5 ba f3 /...P...L A...58...
0050 c5 80 f9 57 31 63 09 6f 0f ff 07 04 a3 de fd ea ...MLTC O...
0060 03 84 ae 06 eb 81 3e 69 b0 5e b3 1d dc 75 14 42 ...N...S...U...B
0070 b8 38 a8 78 af 9e 4a 5b 44 ab d2 df a2 0e ef 36 8...X...J] D...6
0080 e1 44 26 c9 63 05 ab 46 e1 a5 d5 00 3a ec e5 06 D6...C...F...g...f
0090 fe ed ea f5 c8 63 c2 00 47 b1 36 f9 11 ab 73 ce ...C...G...6...s
00a0 91 00 01 f1 9b 5d 5f 53 37 74 e2 15 a7 30 9b fa ...I...S...7...0...
00b0 25 f5 1c 0b 0e 77 30 f3 33 3b dd 9b ab 29 5a ub ...k...o...3...jz
00c0 72 4f 14 ba d4 c5 80 99 f1 4a e7 aa 07 ef fd 6a rO...n...m...[...j
00d0 0f 49 6c 92 9c 0c af 6d 82 a5 61 52 00 42 b8 db IL...n...m...B...
00e0 0f 0c 05 65 c4 0d ee 53 3b bc 5e 70 6e 5e 24 e1 ...e...S...ym...4...
00f0 52 63 df c9 d1 dd 04 ce f1 5d 69 83 84 d1 82 dc R...n...[...l...
0100 6f 73 1c db ba 76 dd 25 60 62 0d cb 1c 39 7f 8a os...v...%...b...9...
0110 dd ae b3 0c c8 72 5d 1b 2c eb 1a cd 93 92 25 2a ...n...J...[...%...
```

Frame (712 bytes) | Reassembled TCP (2094 bytes) | Basic Credentials (12 bytes)

Once inside the admin panel, the attacker attempted to upload a file with the intent of establishing a reverse shell. Can you identify the name of this malicious file from the captured data?

```
Wireshark · Follow HTTP Stream (tcp.stream eq 9460) · web server.pcap

POST /manager/html/upload;jsessionid=0DE586F27B2F48D0CA045F731E0E9E71org.apache.catalina.filters.CSRF_NONCE=83EDF4E2462ECC725BAF342DD7A46974 HTTP/1.1
Host: 10.0.0.112:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://10.0.0.112:8080/manager/html
Content-Type: multipart/form-data; boundary=-----309854885940911807712888696060
Content-Length: 1324
Origin: http://10.0.0.112:8080
Authorization: Basic YWRtaW46dG9tY2F0
Connection: keep-alive
Cookie: JSESSIONID=0DE586F27B2F48D0CA045F731E0E9E71
Upgrade-Insecure-Requests: 1

-----309854885940911807712888696060
Content-Disposition: form-data; name="deployWar"; filename="JXQOZY.war"
Content-Type: application/octet-stream

PK.....r*W.....WEB-INF/PK.....r*W.*.....WEB-INF/web.xmlm..
.0...5g..q.Z.....#bJ.&...7B..o...7k...U.....|.....:..pg.+...b.
...6<.J...I..U.R.0.....
...%x...+...#...!7c..1.....i)13..v...2..v'6.!.....r.\..y...W0.VJ.k.....?..?..PK.....r*W...T.D.....rZpmxmm.jsp}T0k.0~....
...l+{..Z...J...k.%#..q...^.....}.}w:...x...R*...MLy...spq7.=...#a&G...M...@.c.ai...#...H5...Z...~...2...^4.ce...b...A2H...l.Z...3M
...1...[...Zq...F...T%...*.Pa.l.A..58...W1c...o...N...>i...^...u.B.8.x..J[D...6.D&c.c.F.....f.....c..G.6...s.....] S7t...0...%..k.w0.3;...)Z.
r0...J...j..IL...m...aR.B...e...
S;^yn^4.Rc...ji...os...v.%'b
...9...].]...%*.N.i.F\..R#.d...>v.....j...B..2.....y.G.....l.(@.q...)-6l.ye...t.....>..3.Z.L.f.M...}.....s%+.5...!k..^)>.t...4...))
N)m...%w...j.+C.....@...PK.....r*W.....WEB-INF/PK.....r*W.*.....6...WEB-INF/web.xmlPK.....
...r*W...T.D.....
...rZpmxmm.jspPK.....X.....
-----309854885940911807712888696060--

HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=AC3CF46F608CD09D04A2FF7BE43A3FDC; Path=/manager; HttpOnly
Content-Type: text/html; charset=utf-8
Transfer-Encoding: chunked
Date: Sun, 10 Sep 2023 18:22:15 GMT

<html>
<head>
<styles>
H1 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:22px;} H2 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:16px;} H3 {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:14px;} BODY {font-family:Tahoma,Arial,sans-serif;color:black;background-color:white;} B {font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;} P {font-family:Tahoma,Arial,sans-serif;background:white;color:black;font-size:12px;}A {color : black;}A.name {color : black;}HR {color : #525D76;}
table {
width: 100%;
}
td.page-title {
text-align: center;
vertical-align: top;
font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:14px;
}

```

Answer: JXQOZY.war

After the attacker established a reverse shell on our server, the payload connects back to the attacker's machine. From the analysis, what is the callback destination in `IP:port` format?

For this task, we will filter the traffic being sent from target host. We used filter for the packets with no ACK, because we want to see very first packet initiating the connection.

```
ip.src == 10.0.0.112 and tcp.flags.syn == 1 and tcp.flags.ack == 0
```

No.	Time	Source	Destination	Protocol	Length	Info
28646	556.299692	10.0.0.112	14.0.0.120	TCP	74	55162 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3538440678 TSecr=0 WS=128
28689	713.552599	10.0.0.112	14.0.0.120	TCP	74	35790 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3538597931 TSecr=0 WS=128

Answer: 14.0.0.120:443